

2η Εργασία — Ασφάλεια Συστημάτων

Secure File Storage System — Αναφορά Υλοποίησης

Πανεπιστήμιο Ιωαννίνων — Τμήμα Πληροφορικής & Τηλεπικοινωνιών

1. Περιγραφή Υλοποίησης ανά Μόρος

A — **Hash & Salt**: hash_password()/verify_password() με PBKDF2-HMAC-SHA256 (390.000 επαναλήψεις, salt 16 bytes, κλειδί 32 bytes) μέσω cryptography. Salt ανά χρηστή + πολλαπλές επαναλήψεις δυσκολεύουν brute-force/rainbow table.

B — **OTP & Εγγραφή**: register_user() ελέγχει παρξη, μη-χρση και ορθότητα (case-insensitive) του OTP. Μετ την επιτυχή χρση σημεινεται used=True (μονχρηστο), υπολογζεται hash+salt και δημιουργονται αυματα κλειδι RSA.

Γ — **Αυθεντικοποίηση**: authenticate_user() ανακτ hash/salt και καλε verify_password(). Σε κθε αποτυχία (user δεν υπρχει ή λθος κωδικς) εμφανζεται το ιδιο γενικ μνυμα, στε να μην ειναι δυνατ η απαρθμιση γκυρων usernames (user enumeration).

Δ — **Κλειδί RSA**: Δθηκε τοιμο, χρησιμοποιθηκε αυτοοιο: RSA-2048 ζεγος αποθηκευνο σε PEM στο keys/.

E — **Anti-Replay / Nonce**: is_nonce_valid() ελέγχει αν το nonce χει ξαναχρησιμοποιηθε (→ απρριψη) ή ειναι νλο (→ αποθκευση με timestamp). Bonus: αυματος καθαρισμς nonces >24 ωρν.

ΣΤ — **Κρυπτογράφηση & Υπογραφή**: encrypt_file(): τυχαο κλειδί 32B + nonce 12B, AES-256-GCM (authenticated encryption). sign_data(): RSA-PSS/SHA-256 πνω στο (data+nonce), στε η υπογραφή να δεσμεεται και στο συγκεκριμνο ατημα, χι μνο στο περιεχμενο.

Z — **Upload / Download / CLI**: upload_file(): read → nonce → sign → anti-replay check → encrypt → save (.enc + metadata .json σε base64). download_file(): αυστροφη ρο + επαλθευση υπογραφς πριν την τοπικ αποθκευση. Το CLI διατηρε session (logged_in_user) — Upload/Download απαιτον ενεργ σνδεση.

2. Παράδειγμα Εκλέσεως (πραγματικ transcript)

Πραγματικ εκλέση: κδοση OTP → αποτυχημνη εγγραφή (λθος OTP) → επιτυχς εγγραφή → αποτυχημνη/επιτυχς σνδεση → upload → download με επαλθευση υπογραφς → replay attack.

```
>>> admin_issue_otp('bob')
[ADMIN] OTP για 'bob': 93AF0752

>>> register_user('bob', <λθος OTP>, 'Str0ngP@ss')
[ΣΦΑΛΜΑ] Λανθασμνο OTP.

>>> register_user('bob', '93AF0752', 'Str0ngP@ss')
[OK] Ο χρστης 'bob' εγγρθηκε επιτυχς.

>>> authenticate_user('bob', 'WrongPassword')
[ΣΦΑΛΜΑ] Λθος στοιχεα σνδεσης.

>>> authenticate_user('bob', 'Str0ngP@ss')
[OK] Επιτυχς σνδεση ως 'bob'.

>>> upload_file('bob', 'confidential.txt')
[OK] Το αρχεο 'confidential.txt' ανβηκε και κρυπτογραφθηκε επιτυχς.

>>> download_file('bob', 'confidential.txt')
[OK] Η ψηφιακ υπογραφή του χρστη 'bob' επαληθετηκε επιτυχς.
[OK] Το αρχεο αποθηκετηκε ως 'downloaded_confidential.txt'.

>>> --- Προσομοωση Replay Attack ---
>>> is_nonce_valid('940e24...f51') # 1η χρση -> True

>>> is_nonce_valid('940e24...f51') # 2η χρση (replay)
[ΠΡΟΕΙΔΟΠΟΙΗΣΗ] Εντοπστηκε πθαν Replay Attack — το nonce χει δη χρησιμοποιηθε!
```

Σημωση: Επισυνψτε επςες πραγματικ screenshots απ την εκλέση του CLI (python secure_storage.py): εγγραφή με OTP, σνδεση, upload, download, απρριψη replay.

3. Ανάλυση Μηχανισμν Ασφάλειας

Μηχανισμς	Τι προστατει	Πς
PBKDF2 + Salt	Επιθσεις brute-force / rainbow table στους κωδικς	390,000 επαναλήψεις SHA-256 + μοναδικ salt ανά χρστη
OTP μονς χρσης	Μη εξουσιοδοτημνη εγγραφή λογαριασμν	Το OTP επισημανεται used=True μετ την πρτη επιτυχή χρση
Γενικ μνυμα σβλματος	User enumeration κατ τη σνδεση	Το ιδιο μνυμα για «δεν υπρχει» και «λθος κωδικς»
AES-256-GCM	Εμπιστευτικτητα + ακεραιτητα αρχεων	Authenticated encryption· νλο τυχαο κλειδί/nonce ανά αρχεο
RSA-PSS + SHA-256	Μη-αποποήση (non-repudiation) και ακεραιτητα αυτων	Υπογραφή του αυτουστο (data + nonce) με το ιδιωτικ κλειδί του χρστη
Nonce / Anti-Replay	Replay attacks (επανλήψη παλιο γκυρου αυτουστο)	Αποθκευση και επαλθευση nonces καταγραφεται· επανχρησ του απορρπτεται

Nonce στην υπογραφή: αν η υπογραφή κλυπτε μνο το περιεχμενο του αρχεου, νας επιτιθμενος θα μποροσε να υποκλψει να παλι ή γκυρο ζεγος (δεδομνα+υπογραφή) και να το ξανασελει — η υπογραφή θα παρμενε γκυρη. Επειδ το nonce συμπεριλαμβνεται στο υπογεγραμμνο payload, κθε ατημα δνεται με να μοναδικ, μονχρηστο αναγνωριστικ.

AEAD (AES-GCM) αντ■ απλο■ **AES-CBC**: το GCM παρ■χει ταυτ■χρονα εμπιστευτικ■τητα και ακεραι■τητα. Τροποποι■ντας πειραματικ■ ■να byte εν■ς αποθηκευμ■νου .enc αρχε■ου, η decrypt_file() απ■τυχε με σφ■λμα επαλ■θευσης, ■πως αναμεν■ταν, αντ■ να επιστρ■ψει αθ■ρυβα λανθασμ■να δεδομ■να.

4. Συμπερ■σματα

Η εργασ■α συνδ■ασε πρακτικ■ πολλαπλο■ς μηχανισμο■ς ασφ■λειας σε ■να ενια■ο pipeline: ασφαλ■ αποθ■κευση κωδικ■ν (PBKDF2+salt), ελεγχ■μενη εγγραφ■ μ■σω μον■χρηστου OTP, συμμετρικ■ κρυπτογρ■φηση με ακεραι■τητα (AES-GCM), ασ■μμετρη ψηφιακ■ υπογραφ■ για μη-αποπο■ηση (RSA-PSS), και προστασ■α απ■ replay attacks μ■σω nonce. Κ■θε επ■πεδο καλ■πτει διαφορετικ■ απειλ■, δε■χγοντας π■ς σχεδι■ζεται ■να ρεαλιστικ■ σ■στημα ασφαλο■ς αποθ■κευσης αρχε■ων.